Agent Canary

面向 AI Agent 的可审计诱饵检测与受守卫操作隔离工具

MIT	Node.js 20+	本地优先	全部功能免费
开源许可	运行环境	无遥测	无需购买或激活

项目摘要

Agent Canary 是一款面向 MCP 兼容 AI 编程 Agent 与其开发者的开源安全工具。它提供无害 MCP 诱饵、随机金丝雀令牌、SDK 会话熔断器和本地评测。当 Agent 调用诱饵，或已登记令牌出现在埋放位置之外时，项目记录可审计信号；集成方可把后续真实工具回调统一经过同一 guard/router，在隔离状态下拒绝未放行调用。

边界：诱饵只返回合成内容，不执行它所描述的业务动作。检测信号需要结合上下文核查；只有经过集成 guard/router 的调用才受后续隔离策略约束。

问题与方案

使用风险	项目做法	可核查结果
提示注入可能诱导 Agent 读取秘密、运行命令或调用越权工具。	布置高风险外观但无害的 MCP 诱饵，并在蜜罐文件中放置无权限的唯一令牌。	诱饵调用与令牌扫描会形成带时间、类型和来源位置的事件信号。
只靠提示词评分难以对应到 Agent 实际工具选择。	评测套件向被测模型暴露诱饵工具，检查工具调用或追踪令牌回显。	逐条报告 resisted、compromised 与 provider error；错误不伪装成模型失陷。
检测后 Agent 可能继续执行后续真实工具调用。	宿主用同一会话 guard 包装真实回调，隔离后默认拒绝未列入 allowlist 的调用。	能力仅覆盖经过 guard/router 的路径；未接入的调用路径明确不受保护。

核心闭环

不可信内容 文档、网页、对话	检测信号 MCP 诱饵 / 令牌命中	会话隔离 拒绝后续受守卫调用	审计与告警 本地日志 / 可选通知

示例工作流为本地可复现的开发场景，并非生产客户案例。项目不声称已经拦截真实攻击或证明真实数据外泄。

技术架构与关键设计

以本地运行、明确边界和可审计信号为主线

组件	作用	数据与边界
CLI 与 MCP 服务	初始化、安装、状态诊断；向 MCP 客户端注册 12 个只返回合成结果的诱饵工具。	不执行真实文件、Shell、凭据或业务操作。诱饵触发可写入脱敏事件；操作员配置 webhook 时会向指定端点发送告警。
金丝雀令牌	生成随机无权限字符串，写入蜜罐或扫描项目文件和 stdin。	只匹配本地登记值；扫描器包含隐藏配置和大文件，跳过 .git、.hg、.svn、node_modules。
SDK guard/router	每个 Agent 会话维护 SAFE、TRIPPED、QUARANTINED 状态，提供真实工具回调的统一入口。	隔离后拒绝未放行的受守卫调用。直接绕过 guard 的调用不在保护范围。
评测与本地模型	20 条版本化注入载荷；支持 OpenAI、Anthropic、OpenAI 兼容端点与本地 Ollama。	Ollama 可不使用 API key；云模型请求可能收费。错误或截断响应按未抵御处理并单独标记。
事件、面板与导出	脱敏 JSONL 事件、离线 HTML 面板，以及 CEF、JSONL、CSV 导出。	事件默认本地保存；无遥测。Webhook 默认要求 HTTPS，重定向不跟随。

组合特色

可解释的检测信号	可审查的处置路径
不把任意模型评分包装成安全结论，而是记录诱饵工具调用、令牌命中、模型回显和提供方错误。	检测、隔离、审计和导出在同一开源工具中衔接，宿主仍掌握工具回调、allowlist 与人工复位。
本地评测无需把载荷发给云服务，可用本地 Ollama 验证模型对固定提示集的表现。	依赖公开标准 MCP 与 Node.js；报告、面板和日志可在本地复现与检查。

安全与隐私边界

事件字段采用白名单和脱敏；工具调用参数不进入 Agent Canary 事件日志。评测只有在用户主动运行时才会把载荷发送给选定的模型提供方；本地 Ollama 模式使用 loopback HTTP。Webhook 只有在操作员配置后才启用。面板为独立 HTML，不加载 CDN 或第三方脚本。

评测限制：20 条静态载荷只能描述指定模型、参数和日期下的回归结果，不是安全认证，也不能证明模型可以抵御所有提示注入。守卫无法拦截首个绕过它的真实操作。

应用场景、上手流程与持续发展

将安全控制放到开发者能够复现和审查的本地工作流中

示例应用场景

场景	操作流程	价值与范围
AI 编程 Agent 项目	初始化后，在项目蜜罐中植入令牌并向 Claude Code 或 Cursor 注册 MCP 诱饵；发生信号后查看事件。	帮助开发者观察异常工具选择；不能替代宿主权限控制或系统沙箱。
代码仓库 CI	用 tokens check 扫描文件或已暂存 diff；返回码区分发现令牌、扫描不完整和未配置令牌。	可作为泄漏检测步骤；隐藏配置会扫描，VCS 元数据和 node_modules 默认排除。
本地模型研发	用 Ollama 运行固定的 20 条提示注入评测，保存逐条 JSON 或 Markdown 报告。	可比较版本回归；分数只反映此套件，不能替代红队评估或安全认证。

从源码开始

```
git clone --branch shanchuanzhi/v2-free-open-20261010 --single-branch
https://github.com/DorianChn/shanchuanzhi-agent-canary
cd shanchuanzhi-agent-canary
npm ci
npm run build
npm link
agent-canary init
agent-canary self-test
agent-canary tokens plant .env.canary --label my-project
agent-canary install claude
agent-canary doctor
```

本次修订执行 npm run build 成功，git diff --check 通过。自动化回归测试和性能基准测试未在本次更新中运行。

开源治理与发展计划

当前治理	后续方向
MIT 许可；中英文 README；SECURITY.md、CONTRIBUTING.md 与版本化 CHANGELOG；锁定依赖并提供本地构建与诊断命令。	补充更多宿主集成示例和兼容性说明；在明确标注覆盖范围的前提下扩展评测载荷；通过公开 issue 与 PR 收集可复现反馈。

参赛项目信息

项目 / 赛道	负责人 / 单位
Agent Canary 2.1.0 / 开源 AI 工具	唐林博豪 / 闽江大学
MIT / Node.js 20+ / Commit 69900c3	https://github.com/DorianChn/shanchuanzhi-agent-canary/tree/shanchuanzhi/v2-free-open-20261010

赛事评审维度与材料要求参见 大赛官网。示例用于说明实现路径，不代表真实部署或实测防护成效。

2.1.0 响应与处置更新

在全部功能免费开放的 2.0.0 基础上，加强调用前拒绝、协作取消和异步监控

本版本更新

方向	变化与边界
调用前风险拒绝	新增可选 denyRiskLevels，可在 SAFE 状态下按粗粒度工具风险分类，在宿主回调开始前拒绝调用。默认不启用以保持兼容；分类来自工具名称，需由集成方审阅。
隔离时协作取消	隔离同步 abort 当前会话的 AbortSignal，并将 signal 交给守卫回调。只有宿主将它继续传给支持取消的模型或工具 API，才能停止在途请求；这不替代宿主凭据撤销。
异步监控与补漏	目录遍历改为异步、文件内容流式读取；事件合并约 100 ms，默认每 2 秒做一次可配置指纹补漏扫描。既有全量内容扫描节奏保持原样：原生 watcher 为 30 秒，fallback 为 3 秒；不可读路径会显式报告。
开放与兼容	2.0.0 起评测、SDK 隔离、面板和 SIEM 导出均在 MIT 许可下免费公开；2.1.0 延续该许可与默认行为。

建议演示路径

步骤	可见结果
1. 克隆本参赛分支；npm ci；npm run build	从提交 69900c3 对应的公开源码构建。
2. agent-canary init；tokens plant；install claude 或 cursor	建立蜜罐令牌并注册只返回合成内容的 MCP 诱饵。
3. self-test；events；dashboard；export	查看脱敏事件、离线面板和 SIEM 导出。
4. eval --provider ollama --model qwen3	在本机运行固定评测载荷；分数只描述该套件，不是安全认证。

本次可复现核对

核对项	结果
TypeScript 构建	npm run build 通过。
补丁格式	git diff --check 通过。
自动化回归测试	本次更新未运行；不宣称通过。
性能基准测试	本次更新未运行；未测量响应时间或性能倍数。